Seguridad en Networking

Clase 2

¿Cómo me siento?

0
false

1
true

Objetivo

AE: Aplican medidas de seguridad en redes, considerando principales amenazas, controles de protección y accesos seguros a dispositivos para la mitigación de riesgos en entornos de red.

Obj: **Analizar mecanismos de protección y segmentación de red**, identificando cómo los firewalls, VPN y técnicas de aislamiento contribuyen a la mitigación de vulnerabilidades en distintos escenarios de seguridad en redes.

¿Qué es una Amenaza?

Circunstancia, acción o agente capaz de explotar una vulnerabilidad.

Impacto medido en **Modelo CIA**:

- **Confidencialidad:** Solo acceso autorizado.
- **Integridad:** Información no alterada sin permiso.
- **Disponibilidad:** Sistemas accesibles cuando se necesitan.

Modelo CIA o Triada CIA: Confidentiality, Integrity, and Availability of information

Clasificación general

Malware	Ataques de red	Ingeniería social	Amenazas internas	Amenazas externas
Virus, gusanos, troyanos, ransomware, spyware, rootkits, adware malicioso.	DoS/DDoS, MitM, sniffing, spoofing, ARP poisoning, DNS hijacking.	Phishing, spear phishing, vishing, smishing, pretexting, baiting, tailgating.	Insider malicioso, error humano, negligencia.	Ciberdelincuentes, hacktivistas, espionaje industrial, APT.

Estándares y buenas prácticas

Garantizar la **Confidencialidad, Integridad y Disponibilidad** de la información mediante el cumplimiento de normas y la aplicación de controles efectivos.

ISO/IEC 27001 – *Gestión de Seguridad de la Información*

- Define un **Sistema de Gestión de Seguridad de la Información (SGSI)**.
- Establece políticas, procedimientos y controles.
- Ejemplo aplicado: Documentar políticas de contraseñas, acceso remoto seguro (VPN/Tailscale) y gestión de incidentes.

ISO/IEC 27002 – *Controles de Seguridad*

- Guía práctica con **controles de seguridad** técnicos y organizativos.
- Ejemplo aplicado: Configuración segura de servidores, uso de autenticación multifactor (MFA), segmentación de redes y cifrado de datos en tránsito.

Estándares y buenas prácticas

Garantizar la **Confidencialidad, Integridad y Disponibilidad** de la información mediante el cumplimiento de normas y la aplicación de controles efectivos.

NIST Cybersecurity Framework – *Marco de Ciberseguridad*

- 5 funciones clave: **Identificar, Proteger, Detectar, Responder, Recuperar**.
- Ejemplo aplicado: Monitorear logs del firewall (Detectar), aplicar parches de seguridad (Proteger), y tener plan de respuesta ante ataques DDoS (Responder).

Zero Trust Architecture – *“Nunca confíes, verifica siempre”*

- Acceso bajo privilegios mínimos.
- Ejemplo aplicado: Autenticación continua para administradores, segmentación de VLAN por departamento.

Estándares y buenas prácticas

Garantizar la **Confidencialidad, Integridad y Disponibilidad** de la información mediante el cumplimiento de normas y la aplicación de controles efectivos.

Defensa en Profundidad – *Capas de Seguridad*

- Combinar múltiples barreras: firewall, Sistemas de Detección de Intrusiones (IDS), Sistemas de Prevención de Intrusiones (IPS), antivirus, autenticación, segmentación de red.

- Ejemplo aplicado:

  - **Capa 1:** Firewall de red (bloquea accesos no autorizados).
  - **Capa 2:** IDS/IPS (detecta y bloquea ataques).
  - **Capa 3:** Cifrado y control de acceso.

Recursos recomendados:

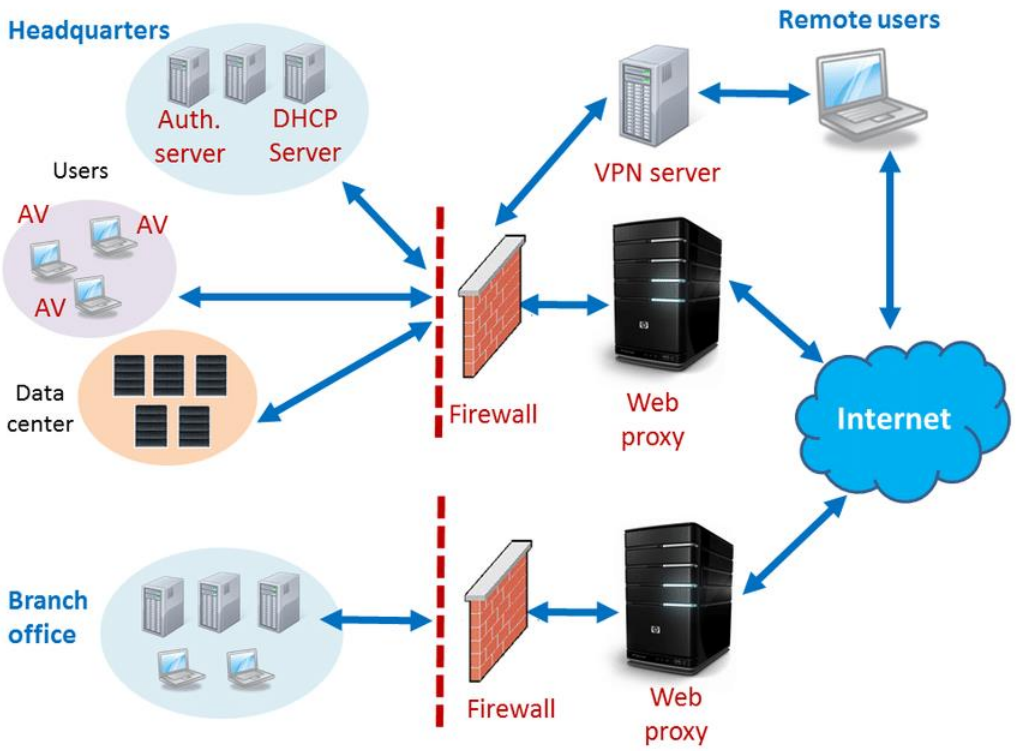
- ISO 27001 Overview: https://www.iso.org/isoiec-27001-information-security.html
- NIST CSF: https://www.nist.gov/cyberframework
- CISA Best Practices: https://www.cisa.gov/resources-tools

¿Qué es un Firewall?

Sistema de seguridad que **filtra tráfico de red** entrante y saliente según reglas definidas.

Primera línea de defensa contra accesos no autorizados.

Puede ser **software** (instalado en un servidor/PC) o **hardware** (dispositivo dedicado).



Por Software

Gratuitos:

- **pfSense** → open source, muy usado en empresas pequeñas y medianas.
- **IPFire** → basado en Linux, sencillo para segmentación y VPN.
- **UFW (Uncomplicated Firewall)** → en Linux, reglas simples con iptables.

De Pago:

- **Sophos XG Firewall** → incluye IDS/IPS, VPN y protección avanzada.
- **Check Point ZoneAlarm Pro** → enfoque en endpoint y laptops corporativas.

Por Hardware

Gratuitos/Open Source (requieren hardware propio):

- **OPNsense (fork de pfSense)** → instalable en appliances o PCs reciclados.

De Pago:

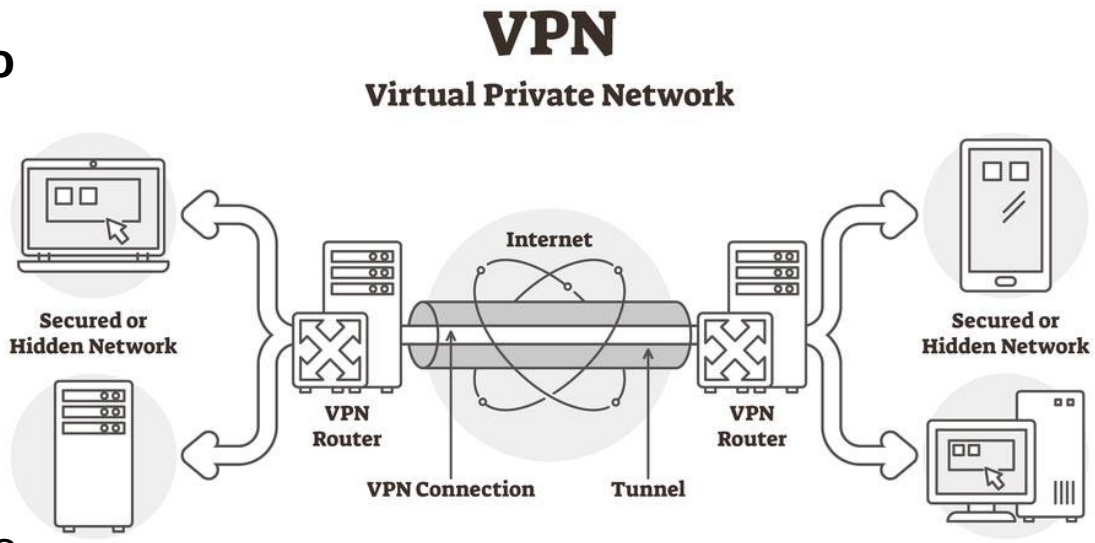
- **Cisco ASA / Firepower** → estándar en grandes corporaciones.
- **Fortinet FortiGate** → muy usado en banca y retail.
- **Palo Alto Networks NGFW** → top en seguridad avanzada con machine learning.

¿Qué es una VPN?

Red privada virtual que **cifra el tráfico de red** y permite **acceso seguro y remoto** a sistemas internos.

Protege contra **interceptación, sniffing y ataques en redes públicas (Wi-Fi, ISP, etc.)**.

Puede implementarse por **software** (cliente en PC/móvil) o **hardware** (gateway dedicado).



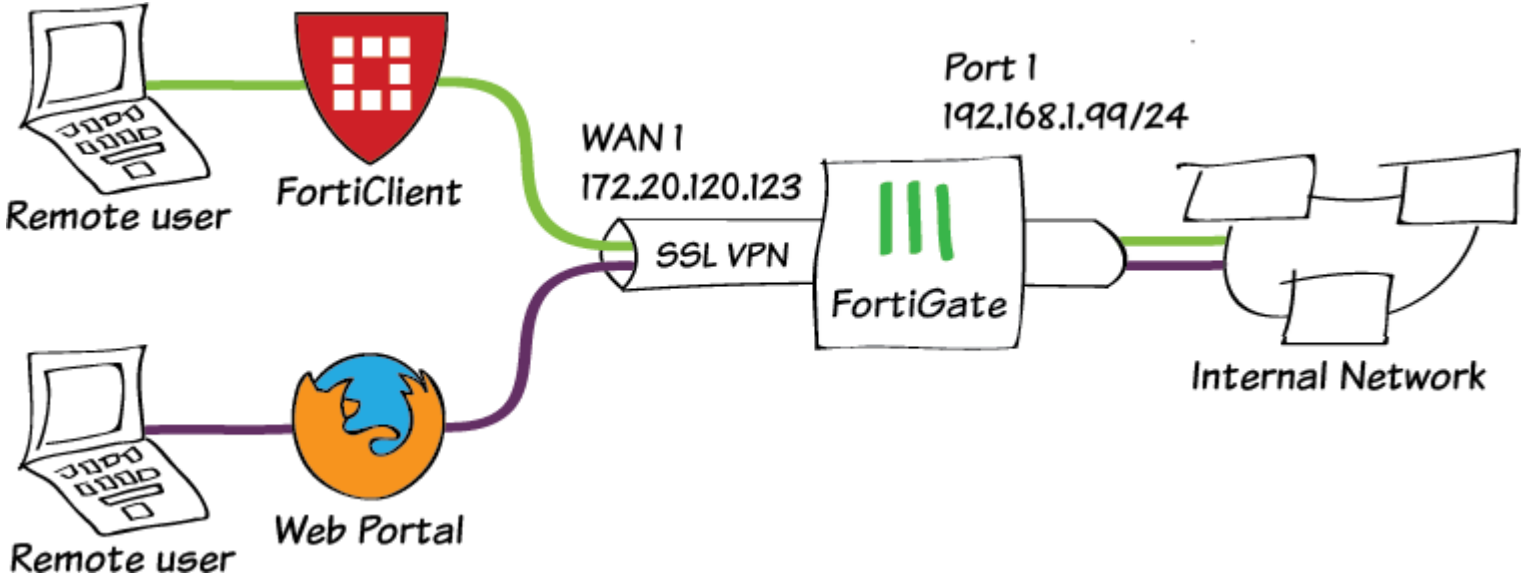
Por Software

- **Gratuitas / Open Source:**
  - **OpenVPN** → estándar abierto, soporta túneles SSL/TLS.
  - **WireGuard** → rápido, seguro, integrado en Linux Kernel.
  - **SoftEther VPN** → multiprotocolo (OpenVPN, L2TP, SSTP).

- **Modernas / Zero Trust:**
  - **Tailscale** → basado en WireGuard, crea una red privada entre dispositivos, gestión simple, ideal para equipos distribuidos.
  - **Cloudflare Zero Trust (Cloudflare Tunnel / Access)** → protege aplicaciones y redes sin necesidad de abrir puertos, integra autenticación (Google, Azure, etc.).

Por Hardware

- **Fortinet FortiGate VPN** → appliance dedicado con firewall integrado.
- **Cisco Meraki VPN** → administración en la nube, ideal para pymes.
- **Palo Alto GlobalProtect** → acceso seguro con Zero Trust.



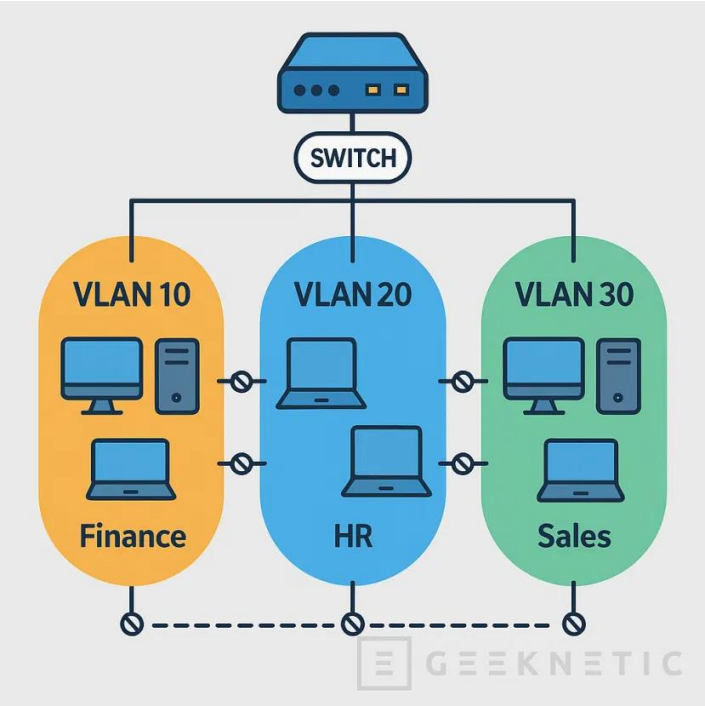
Segmentación de Redes

La segmentación consiste en **dividir una red en subredes o segmentos** más pequeños, aplicando reglas de seguridad y control de acceso, con el objetivo de **reducir el impacto de amenazas** y aumentar el control del tráfico.

Recursos

- [Calculadora de Subredes]
- [¿Qué es la segmentación de redes?]

Métodos de Segmentación



VLAN (Virtual LAN):

- Separación lógica de redes en un mismo switch.
- Ej: VLAN estudiantes, VLAN docentes, VLAN administración.

Subredes (Subnetting):

- División de red IP en bloques más pequeños.
- Ej: separar red 192.168.1.0/24 en subredes para impresoras, servidores y usuarios.

DMZ (Zona Desmilitarizada):

- Segmento aislado para servidores expuestos a Internet (web, correo).

Microsegmentación (Zero Trust):

- Uso de firewalls internos o SDN (Software Defined Networking) para controlar tráfico entre workloads o contenedores.

Métodos de Autenticación

Contraseña (Password-based):

- Lo más común, pero vulnerable si es débil.

MFA (Multi-Factor Authentication):

- Algo que sabes (contraseña) + algo que tienes (token/APP) + algo que eres (biometría).

Certificados Digitales (PKI):

- Se usan en VPN, HTTPS y redes corporativas.

Tokens / Aplicaciones:

- Ej. Google Authenticator, Authy, Microsoft Authenticator.

Protocolos de Control de Acceso

SSH (Secure Shell):

- Reemplazo seguro de Telnet.
- Autenticación por clave pública/privada.

RADIUS (Remote Authentication Dial-In User Service):

- Centraliza la autenticación para Wi-Fi y VPN.

TACACS+:

- Control granular en dispositivos de red Cisco.

LDAP (Lightweight Directory Access Protocol):

- Integración con directorios (ej. Active Directory).

Zero Trust Access (ZTA):

- Cada solicitud se valida, sin confianza implícita en la red.

Cierre

Amenazas en Redes

- Pueden ser internas o externas.
- Malware, ataques de red e ingeniería social siguen siendo los más frecuentes.

Mecanismos de Protección

- **Firewalls** (software y hardware).
- **VPN y segmentación de red** para proteger tráfico y aislar riesgos.

Cierre

Autenticación y Control de Acceso

- Contraseñas seguras ya no bastan → usar **MFA**.
- Protocolos seguros: **SSH, RADIUS, TACACS+, LDAP**.
- Modelo **Zero Trust**: nadie entra sin verificar.

Buenas Prácticas y Estándares

- ISO/IEC 27001 y 27002 → gestión y controles de seguridad.
- Defensa en profundidad: múltiples capas (red, dispositivo, usuario).
- Registro y monitoreo constante.

Conclusión

"Una red segura no depende de un solo muro, sino de varias barreras inteligentes que se complementan: protección, autenticación, segmentación y cultura de seguridad."